Risk Register & Maintenance Plan

ABU-SSO: Unified Single Sign-On & Digital Campus Wallet

Course: COEN838 — Advanced Software Engineering
Student: Idris Muhammad Abubakar
Matric No: P25EGCP9003

Part 1 — Risk Register

This register lists the principal risks that could affect the successful delivery, security, or long-term operation of ABU-SSO. Each risk is quantified using the formula:

Risk Exposure (RE) = Probability × Impact

Where Probability is rated L (Low = 0.2), M (Medium = 0.5), H (High = 0.8) and Impact is rated on a 1–5 scale (1 = negligible, 5 = critical).

ID	Risk	Category	Probability	Impact	RE	Mitigation	Status
R1	JWT secret leaked via Git history or `.env` misconfiguration	Security	M (0.5)	5	2.5	`.env` is gitignored; secret stored as env variable on deployment platform; key ≥32 bytes; rotate on suspicion	Managed
R2	Weak user passwords allow credential stuffing	Security	H (0.8)	3	2.4	Enforce min 6 chars via Pydantic; recommend password manager; future: add zxcvbn strength check	Partial
R3	SQLite write-lock contention at scale	Technical	M (0.5)	3	1.5	Documented migration path to PostgreSQL — single env-var change (`DATABASE_URL`); SQLAlchemy abstracted	Managed
R4	Course workload causes deadline overrun	Project	M (0.5)	4	2.0	Agile increments — working prototype already deployed;	Managed

ID	Risk	Category	Probability	Impact	RE	Mitigation	Status
						core features prioritized via MoSCoW	
R5	Exam-day network outage blocks live demo	Operational	L (0.2)	5	1.0	Prototype runs fully offline on localhost; backup screen recording prepared	Managed
R6	Dependency CVE disclosed in FastAPI/Starlette	Security	M (0.5)	4	2.0	Monthly `pip-audit`; Dependabot alerts enabled; refresh `requirements.txt` before submission	Planned
R7	Unauthorized data access via IDOR (Insecure Direct Object Reference)	Security	L (0.2)	5	1.0	Every wallet/ID-card read is scoped to `get_current_user` — no user can supply another user's id	Mitigated

Risk Matrix

mpact → 1 2 3 4 5 P H - - R2 - - r M - - R3 R4,R6 R1 o L - - - - R5,R7 b

Risks with highest exposure: R1 (leaked JWT secret, RE=2.5) and R2 (weak passwords, RE=2.4). Both are actively managed via `.env` isolation and Pydantic validation respectively.

Residual risk after mitigation: All risks reduced to Low or Managed. No risk currently blocks delivery.

Part 2 — Maintenance Plan

Following Sommerville (2016), maintenance is classified into four types. This plan estimates the allocation of engineering effort across each category over the first 12 months after deployment.

2.1 Maintenance Categories & Effort Allocation

Type	% Effort	Driver	Examples for ABU-SSO
Corrective	20%	Reactive	Fix bug reports from students; patch login failures; resolve wallet balance discrepancies
Adaptive	20%	Reactive / Proactive	Migrate SQLite → PostgreSQL; upgrade to Python 3.14; integrate OIDC for ABU ICT; support new browsers

Type	% Effort	Driver	Examples for ABU-SSO
Perfective	50%	Proactive	Add admin dashboard; audit-log viewer; bulk user management; rate limiting; native mobile UI
Preventive	10%	Proactive	Monthly `pip-audit`; refactor hot paths; expand test coverage to 100%; rotate JWT secret every 6 months

This allocation matches the industry pattern where **Perfective + Adaptive ≈ 70%** of maintenance effort, and **Corrective ≈ 20%**.

2.2 Versioning & Release Policy

- **Semantic Versioning:** `MAJOR.MINOR.PATCH` (e.g., `1.2.3`)
- **Branching:** Trunk-based development — every change goes to `main` via a short-lived branch and a pull request.
- **Commit Convention:** Conventional Commits (`feat:`, `fix:`, `docs:`, `test:`, `chore:`, `ci:`, `refactor:`).
- **Release Cadence:** Continuous delivery on every merged PR that passes CI.

2.3 Quality Gates Before Any Release

Every merge to `main` must satisfy:

1. ✅ All **53+ automated tests** pass locally and in CI.
2. ✅ Line **coverage ≥ 70%** (currently 96%).
3. ✅ `bandit -r app/` reports **0 High/Medium findings**.
4. ✅ `.env.example` reflects any new environment variables.
5. ✅ `docs/SRS.md` and `docs/RTM.md` updated for any new Functional Requirement.

2.4 Long-term Support Roadmap

Timeframe	Planned Maintenance
Month 0–3	Corrective bug fixes reported by pilot users; expand test suite
Month 3–6	Adaptive: migrate to PostgreSQL; add Docker Compose for local dev; integrate CI/CD to Render
Month 6–9	Perfective: build admin dashboard (UC-09); add audit log; rate limiting via `slowapi`
Month 9–12	Preventive: dependency refresh; security audit; prepare OIDC (RS256) upgrade
Year 2	Adaptive: integrate with real ABU ICT systems; add native mobile apps

2.5 Metrics to Track in Production

Metric	Target	How Measured
API availability	≥ 99%	UptimeRobot pings on `/health`

Metric	Target	How Measured
Login latency p95	≤ 500 ms	Server logs / APM
CI pass rate	100%	GitHub Actions history
Mean Time To Detect (MTTD)	≤ 5 min	Monitoring alerts
Mean Time To Repair (MTTR)	≤ 2 hours	Incident log
Test coverage	≥ 70%	`pytest --cov`

2.6 Decommissioning Plan

If ABU-SSO is superseded (e.g., by an official ABU ICT identity provider), the migration path is:

1. Export all user data and transaction history to a portable format (CSV/JSON).
2. Notify all users 30 days in advance.
3. Redirect `/.well-known/openid-configuration` to the successor IdP.
4. Archive the repository and preserve SRS/RTM for audit purposes.

Part 3 — Traceability of This Document

Document	Purpose
`docs/SRS.md`	Full requirements specification
`docs/RTM.md`	Requirements traceability matrix
`docs/TECHNICAL_REPORT.md`	Engineering process narrative
`docs/USER_MANUAL.md`	End-user and installation guide
`docs/RISK_AND_MAINTENANCE.md`	This document

End of Risk Register & Maintenance Plan.